

HIPAA Breach Control Gap Analysis

A data-driven review of healthcare data breaches reported to HHS OCR, 2013-2026

Author: Wendy Lacan

Overview

This analysis examines 6,029 healthcare data breaches affecting at least 500 individuals, reported to the HHS Office for Civil Rights “Wall of Shame” between January 2013 and February 2026. The goal was to move beyond simply counting breaches and determine which HIPAA safeguard categories (Administrative, Physical, or Technical) pose the greatest risk to patients.

Each breach was mapped to the HIPAA Security Rule safeguard category most likely associated with its underlying failure. Frequency and impact (individuals affected) were then compared to separate breach categories that occur often but have limited impact from those that are both frequent and catastrophic.

Technical Safeguard Failure Is the Dominant Risk

Technical Safeguard Failure is the only control gap category classified as a Disproportionate Risk in the dataset, with hacking and IT incidents accounting for nearly all of these failures.

Control Gap Category	Breach Count	Impact Share %	Freq Share %	Impact/Freq Ratio	Severity Tier
Technical Safeguard Failure	3,648	91.6%	60.5%	1.51x	Disproportionate Risk
Administrative Safeguard Failure	1,429	4.8%	23.7%	0.20x	Under-represented Risk

In other words, about six out of every ten breaches result from Technical Safeguard Failures, but they account for more than nine in ten of every patient record exposed. In contrast, Administrative Safeguard Failures account for 23.7% of all breaches but only 4.8% of total impact. Although they happen frequently, their overall consequences are much smaller.

Note: Technical Safeguard Failure has a severity ratio of 1.51, which is slightly above the threshold for the Disproportionate Risk category. While this classification depends on the selected cutoff, the overall conclusion does not. Technical Safeguard Failures account for 60.5% of breaches and 91.6% of all affected individuals, demonstrating that they are the dominant source of breach impact regardless of the assigned severity tier.

Supporting Findings

Hacking has become the primary cause of healthcare data breaches, replacing physical breaches as the leading threat. Hacking and IT incidents increased from 10.4% of annual breaches in 2013

to approximately 80% between 2022 and 2024 (slope = +40.83 breaches per year, $R^2 = 0.54$, $p = 0.004$). In contrast, physical breach types, including theft, loss, and improper disposal, declined steadily over the same period (slope = -12.23 breaches per year, $R^2 = 0.91$, $p < 0.001$). Theft alone decreased from 123 incidents in 2013 to just 5 in 2025.

These trends suggest that healthcare organizations have improved in physical safeguards, such as device encryption and secure disposal practices. At the same time, the continued growth of hacking incidents indicates that technical vulnerabilities have expanded more rapidly than security defenses have improved.

Business associate involvement is associated with larger data breaches. Breaches involving a business associate had a median of 4,500 affected individuals, compared with 3,859 for breaches without business associate involvement. This difference was statistically significant (Mann-Whitney U, $p < 0.001$). These findings suggest that strengthening business associate oversight and Business Associate Agreements could reduce breach impact, as business associates often store or manage data for multiple covered entities.

Risk profiles differ across healthcare entity types. Business Associates have the highest proportion of Technical Safeguard Failures (65.3%), reflecting their role in processing and storing large volumes of electronic health data. On the other hand, the Health Plan category has a higher percentage (38.6%) of Administrative Safeguard failures compared to Business Associates (21.2%), suggesting greater weaknesses in administrative policies and access management.

Mega-breaches are uncommon but tend to occur in clusters during certain years. Breaches affecting more than 1 million individuals reached their highest level in 2023, with 37 incidents accounting for nearly 5% of all breaches that year. This pattern suggests that large-scale attacks on vendors serving multiple covered entities contributed to these events.

Attack patterns vary by breach type. Hacking and IT incidents mainly target network servers (62%) and email systems (30%), which indicates that these are the main technical attack points. On the other hand, physical breaches happen in different locations. Theft most often involves laptops, while loss and improper disposal are mainly associated with paper and film records. These patterns suggest that physical breaches require stronger handling and disposal procedures, whereas hacking incidents require improved technical security controls.

Recommendations

The findings of this study suggest several priorities for healthcare organizations. Technical safeguards should receive the highest priority because they account for the greatest share of breach impact. Organizations should also strengthen oversight of business associates by

improving Business Associate Agreements (BAAs) and vendor security requirements, as breaches involving business associates tend to affect more individuals. Although physical breaches have declined steadily for more than a decade, organizations should continue maintaining effective physical safeguards while recognizing that additional investments in this area may have less impact than improvements to technical security. Finally, Health Plans should review and strengthen their administrative controls, particularly policies, procedures, and access management, since they experience a higher proportion of Administrative Safeguard Failures than other healthcare entity types.

Data Notes

- Source: HHS OCR Breach Portal, filtered to breaches affecting 500+ individuals, submitted January 2013-February 2026.
- 2024-2026 breach counts should be interpreted cautiously, as breaches can take up to 24 months to be investigated and finalized by OCR, understating recent-year totals.
- Safeguard category mappings are analytical approximations based on the most likely control failure implied by each breach type/location and are not official OCR determinations.
- Full code and visualizations are available in Jupyter notebooks (01_exploration.ipynb, 02_feature_engineering.ipynb, 03_analysis.ipynb)